



SCS2311 - Cryptography and Information Security

University of Colombo, School of Computing

Lab - 10: Man-in-the-Middle Attack on TLS using OWASP ZAP

1. Objective

This Lab demonstrates a Man-in-the-Middle (MitM) attack on TLS. It aims at educational purposes in a controlled and ethical lab environment. It shows how MitM attacks work when TLS connection by using a ZAP proxy server. ZAP decrypts and re-encrypts traffic using its trusted certificate.

2. Install and RUN the OWASP ZAP

On Ubuntu:

```
sudo apt update && sudo apt install zaproxy -y
```

On Windows/macOS:

Download from OWASP ZAP Official Site (<https://www.zaproxy.org/download/>)

3. Start OWASP ZAP Proxy

- Open ZAP application.
- Go to Tools → Options → Local Proxy and ensure it listens on 127.0.0.1:8080.
- Start ZAP the proxy.

4. Configure Client(Browser) to Use ZAP Proxy

- Open Firefox (recommended for easier certificate control).
- Go to Settings → Network Settings → Manual proxy configuration:
- HTTP Proxy: 127.0.0.1, Port: 8080
- Check "Use this proxy server for all protocols".
- Click OK.

5. Import ZAP's Root CA Certificate to the browser

In ZAP:

- Tools → Options → Dynamic SSL Certificates
- Click "Save" to export the certificate (owasp_zap_root_ca.cer).

In Firefox:

- Go to Settings → Privacy & Security → View Certificates → Authorities
- Click Import, select the exported certificate.
- Trust it for website identification.

6. Perform the Attack

- In Firefox, visit https://<YOUR_SERVER_IP>
- You should see decrypted HTTPS traffic in ZAP under Sites and History.

Warning: If the ZAP certificate is not installed or trusted, the browser will show a TLS certificate warning, preventing the attack.

Submission Instructions: You should capture the screen short of the visited website and the screen short of the ZAP proxy window showing the communication. These screen shorts should be submitted as a single file to the LMS.

++ end +++